

Project ATLAS

Tier 1→2 Escalation Guide & SOAR Playbook

ATLAS-SOAR-001 | Microsoft Sentinel + Entra ID Protection + Defender XDR

Document ID:	ATLAS-SOAR-001	Version:	1.0
Author:	Ivan Yamoah Baoakye	Date:	July 5, 2026
Scope:	Microsoft Sentinel + Entra ID Protection	Incident Ref:	Incident ID 2

PART 1 — Tier 1 Escalation Framework

1.1 Triage Decision Flow

All alerts entering the incident queue follow this decision tree before any remediation action is taken:

INFORMATIONAL / LOW severity

→ Tier 1: Review, document, close as FP or Expected behavior

MEDIUM severity

→ Tier 1 full triage (steps 1.2)

→ Active risk score or prior incidents on entity? → ESCALATE TO TIER 2

HIGH / CRITICAL severity

→ Tier 1: Immediate triage + containment attempt

→ Cannot contain within 15 min? → ESCALATE TO TIER 2

→ Involves admin account / data exfiltration / persistence? → TIER 2 IMMEDIATELY

1.2 Tier 1 Triage Checklist

- **Step 1 — Review incident graph:** Confirm entities (user, device, IP, cloud app). Check alert timeline for sequence. Note AI-generated technique profile.
- **Step 2 — Entity context:** Service account vs. standard vs. admin. Device: MDE enrolled or unmanaged. IP: known Named Location? Cloud app: sanctioned?
- **Step 3 — Prior activity:** Sign-in logs for user over 30 days. Risky users panel — was account already flagged? Same IP hitting other accounts?
- **Step 4 — Classify:** True positive (TP) / False positive (FP) / True positive benign (TP-B)
- **Step 5 — Add incident comment:** Analyst / classification / entities confirmed / evidence summary / action taken (minimum 2 sentences)

1.3 Tier 1 Containment Actions

Action	How	When to use
Confirm user compromised	Entra ID Protection → Risky users → Confirm compromised	TP or anonymous IP sign-in, not authorized
Reset user password	Entra admin center → Users → Reset password	After Confirm compromised
Revoke all active sessions	Entra admin center → Users → Revoke sessions	Immediately on TP compromise
Isolate endpoint (EDR)	Defender for Endpoint → Devices → Isolate	If MDE enrolled, TP malware confirmed
Manual host firewall isolation	netsh advfirewall set allprofiles firewallpolicy blockinboundandoutbound	Un/MDE, unknown, no telemetry, last resort

Action	How	When to use
Disable sign-in	Entra admin center → Users → Block sign-in	Admin accounts pending investigation

1.4 Mandatory Tier 2 Escalation Criteria

Condition	Why Tier 2 required
Compromised account has Global Admin or PRA role	Blast radius is entire tenant
Evidence of lateral movement to other accounts/devices	Scope unknown — full investigation needed
Persistence artifacts found (OAuth apps, scheduled tasks, registry keys)	Escalation requires deep env knowledge
Data access or exfiltration suspected (SharePoint, OneDrive, Exchange)	Legal exchange, forensic considerations
> 5 entities or spans cloud + on-prem	Exceeds Tier 1 scope
Detection rule appears to have misfired or missed scope	T2 owns detection engineering
Technique matches current top-10 threat intel TTPs	Elevated urgency, may need CISO notification

1.5 Tier 2 Handoff Template

TIER 2 ESCALATION – [INCIDENT ID] – [DATE TIME]

Escalating analyst: [NAME]

Escalation reason: [criterion from 1.4]

Summary:

Affected user: [UPN] – Admin/Standard/Service account
 Affected device: [hostname] – Managed/Unmanaged – MDE enrolled: Y/N
 Attack timeline: [first event] → [most recent event]
 Technique(s): [MITRE IDs]
 Containment done: [list from 1.3]

Outstanding risks:

- [What hasn't been contained]
- [What is still unknown]

Priority: [P1 CRITICAL / P2 HIGH / P3 MEDIUM]

PART 2 — SOAR Playbook Design

2.1 Playbook Overview

Playbook name:	ATLAS-PB-001 — Auto-Respond: High Risk Sign-in from Anonymous IP
Trigger:	Sentinel incident created — Entra ID Protection anonymous IP alert
Automation type:	Microsoft Sentinel Playbook (Azure Logic App)
Auth:	Managed Identity (preferred)
MTTR reduction:	35 hours (manual) → ~3 minutes (automated response + notification)

2.2 Playbook Logic

The playbook triggers on every new Sentinel incident and branches based on risk level:

TRIGGER: Sentinel Incident Created
 → Extract UserPrincipalName, IPAddress from incident entities

STEP 1: Enrich – GET /users/{UPN}/authentication/methods
→ MFA registered: True/False

STEP 2: Check risk – GET /identityProtection/riskyUsers?filter=UPN
→ CurrentRiskLevel: none / low / medium / high

CONDITION: riskLevel == 'high' OR severity == 'High'?
YES → BRANCH A (High-risk auto-response)
NO → BRANCH B (Medium-risk notification)

BRANCH A:

Step 3A: POST /identityProtection/riskyUsers/confirmCompromised
Step 4A: POST /users/{userId}/revokeSignInSessions
Step 5A: Add Sentinel incident comment (automated actions documented)
Step 6A: Notify on-call via Teams + Email

BRANCH B:

Step 3B: Add informational comment to Sentinel incident
Step 4B: Notify SOC analyst queue (no auto-containment)

FINAL: Update Sentinel incident status New → In Progress

2.3 Required Graph API Permissions

Permission	Type	Purpose
IdentityRiskyUser.ReadWrite.All	Application	Read risk level, confirm compromised
User.ReadWrite.All	Application	Revoke sessions, read user properties
SecurityIncident.ReadWrite.All	Application	Update Sentinel incidents, add comments
Directory.Read.All	Application	Read group memberships and admin roles

Additionally: assign **Microsoft Sentinel Responder** role to the Logic App's managed identity.

2.4 Playbook Test Plan

Test Scenario	Expected Behaviour
Medium-risk anonymous IP sign-in	Branch B: Teams notification, incident → In Progress, NO auto-containment
High-risk anonymous IP sign-in	Branch A: Confirm compromised API called, sessions revoked, Teams alert
High-risk — user not in Graph	Graceful exit: add comment 'User lookup failed — manual action required'
API failure on revokeSignInSessions	Retry 2x, then notify analyst: 'Session revocation failed'
Incident status update	Sentinel incident changes New → In Progress, owner set to playbook name

2.5 KQL Rule That Triggers This Playbook

```
// Analytics Rule: Anonymous IP Sign-in (High Priority)
// Schedule: Every 5 min | Lookback: 10 min
SigninLogs
| where TimeGenerated >= ago(10m)
| where RiskEventTypes has "anonymizedIPAddress"
| where RiskLevelDuringSignIn in ("medium", "high")
| where ResultType == "0" // Successful sign-in only
| extend City = tostring(LocationDetails.city),
        Country = tostring(LocationDetails.countryOrRegion)
| project TimeGenerated, UserPrincipalName, IPAddress,
        City, Country, RiskLevelDuringSignIn, AppDisplayName
```

| order by TimeGenerated desc

3. Lessons Learned (SOAR Perspective)

The 35-hour gap between Entra ID Protection's first anonymous IP alert (23:14 Jul 3) and analyst triage (10:56 Jul 5) is unacceptable in any production SOC. Had ATLAS-PB-001 been operational:

- T+0 (23:14): Incident created in Sentinel
- T+~1 min: Playbook fires, confirms compromise, revokes sessions
- T+~2 min: On-call notified with full context and automated action log
- T+~3 min: Analyst receives enriched incident, ready for review

Key insight: SOAR makes existing detections faster — it cannot compensate for missing detections. The endpoint telemetry gap (AMA failure) would still leave the brute-force entry point blind even with this playbook running. Fix the telemetry pipeline first (PIR P1), then build the automation.